

CodePath Intermediate Cybersecurity

Unit 1, Project 1 — Catch Me if You Can!

Step-by-Step Guide and Submission Skeleton

Safety

The .pcap files contain **real Windows malware**. Do every step below inside your **Ubuntu VM** (or on a Mac/Linux machine), never on the Windows host. Do not copy extracted objects or .eml files back to Windows. Take your screenshots *inside* the VM and move only the .png images out.

Deliverables at a glance

1. The malicious actor's **IP address**.
2. The **subject lines** of three different phishing emails.
3. A **detailed explanation** of how you found the actor.
4. *Stretch*: three .eml files (screenshots of them opened in a mail client).

1 Set up the environment (in the VM)

- 1.1 Boot your Ubuntu VM. Install Wireshark and the command-line tools:

```
sudo apt update
sudo apt install -y wireshark tshark unzip
```

- 1.2 Download pcap_files.zip *from inside the VM's browser* so it never touches Windows.

- 1.3 Unzip it into its own folder and look at what you have:

```
mkdir -p ~/pj1 && cd ~/pj1
unzip ~/Downloads/pcap_files.zip -d pcaps
ls -lh pcaps/
capinfos pcaps/*.pcap      # capture dates, packet counts, durations
```

2 Triage: which capture has the phishing?

The brief says only **one** capture contains malicious email. Find where the SMTP traffic is first.

- 2.1 Count SMTP packets per file:

```
for f in pcaps/*.pcap; do
  echo "$f: $(tshark -r "$f" -Y smtp 2>/dev/null | wc -l) smtp packets"
done
```

2.2 In the GUI, **Statistics** → **Protocol Hierarchy** gives the same picture visually.

2.3 Keep notes on every file, including the ones that look clean. “I ruled out file X because...” is part of a good explanation.

3 Read the emails

Useful display filters

Filter	What it shows
smtp	all SMTP commands and responses
smtp.req.command == "MAIL"	envelope sender (MAIL FROM)
smtp.req.command == "RCPT"	envelope recipients (RCPT TO)
smtp.req.command == "DATA"	start of each message body
smtp.data.fragment	the body data fragments
imf	reassembled messages (Internet Message Format)
imf.subject contains "..."	search by subject text

3.1 Start with **imf** (or a **data** filter, as the hints suggest). Click a packet and expand the *Internet Message Format* section in the details pane to see the headers.

3.2 Right-click a packet → **Follow** → **TCP Stream** to read the entire SMTP conversation (EHLO, MAIL FROM, RCPT TO, DATA, headers, body).

3.3 Dump a one-line-per-email summary to build your evidence table:

```
tshark -r pcaps/<file>.pcap -Y imf -T fields -E header=y -E separator=' | ' \
-e frame.number -e ip.src -e ip.dst -e imf.from -e imf.to -e imf.subject
```

3.4 Tip: right-click a header field (e.g. *Subject*) → **Apply as Column** to see it in the packet list.

4 Decide: legitimate or fraudulent?

For every email, record the fields below. BEC shows up in *metadata*, not in obvious typos.

Frame	Src IP	MAIL FROM	From:	Reply-To:	Subject	Verdict
-------	--------	-----------	-------	-----------	---------	---------

Questions to ask about each message:

- Does the envelope sender (**MAIL FROM**) match the header **From**:?
- Is there a **Reply-To**: that points somewhere different from **From**:?
- Is the domain a look-alike (swapped letters, extra words, a different TLD)?
- Does the **source IP** match the IP that the organization's real mail comes from?
- What do the **Received**: headers say about the route the message took?
- Does the body ask for money, wire transfers, changed bank details, gift cards, urgency, or secrecy?
- Are there attachments (**Content-Disposition: attachment**)? *Do not open them.*

5 Attribute the actor

- 5.1 Group your fraudulent emails by source IP. Do they share one sender?
- 5.2 Confirm the legitimate emails come from a *different* IP. That contrast is your strongest evidence.
- 5.3 Check what else that IP did in the capture: `ip.addr == <suspect IP>`. **Statistics** → **Conversations** (IPv4 tab) helps here.
- 5.4 Write down frame numbers for every claim, so a grader can verify each one.

6 Stretch: export .eml files (VM only)

- 6.1 With the phishing packets showing, go to **File** → **Export Objects** → **IMF...**
- 6.2 Save three phishing messages as **.eml** into a folder *inside the VM*.
- 6.3 Open each in a mail client in the VM (e.g. `sudo apt install thunderbird`) and screenshot it.
- 6.4 Move only the screenshots out. If antivirus flags anything, that is expected: these are real samples.

Submission skeleton

Copy this structure into the Google Doc template, keeping the template's layout. Fill every [...] in your own words.

Malicious actor IP

[IP address]

Phishing email subject lines

1. [subject 1] (frame [#], capture [file])
2. [subject 2] (frame [#], capture [file])
3. [subject 3] (frame [#], capture [file])

How I found the malicious actor

1. **Triage.** *[Which captures you checked, how, and why you ruled each one in or out.]*
2. **Filtering.** *[The filters you used and what each one revealed. Include screenshots.]*
3. **Red flags.** *[For each phishing email: the specific header or body evidence (From vs. Reply-To, domain, request).]*
4. **Attribution.** *[How the source IP ties the emails together, and how it differs from legitimate mail.]*
5. **Why metadata matters.** *[One or two sentences connecting your evidence to the Key Takeaways.]*

Stretch: .eml screenshots

[Screenshot 1] [Screenshot 2] [Screenshot 3]

Submission checklist

- ☐ All required challenges complete
- ☐ Template layout followed; checklist in the doc ticked
- ☐ Images display correctly
- ☐ Doc sharing set to “Anyone with the link can Edit”